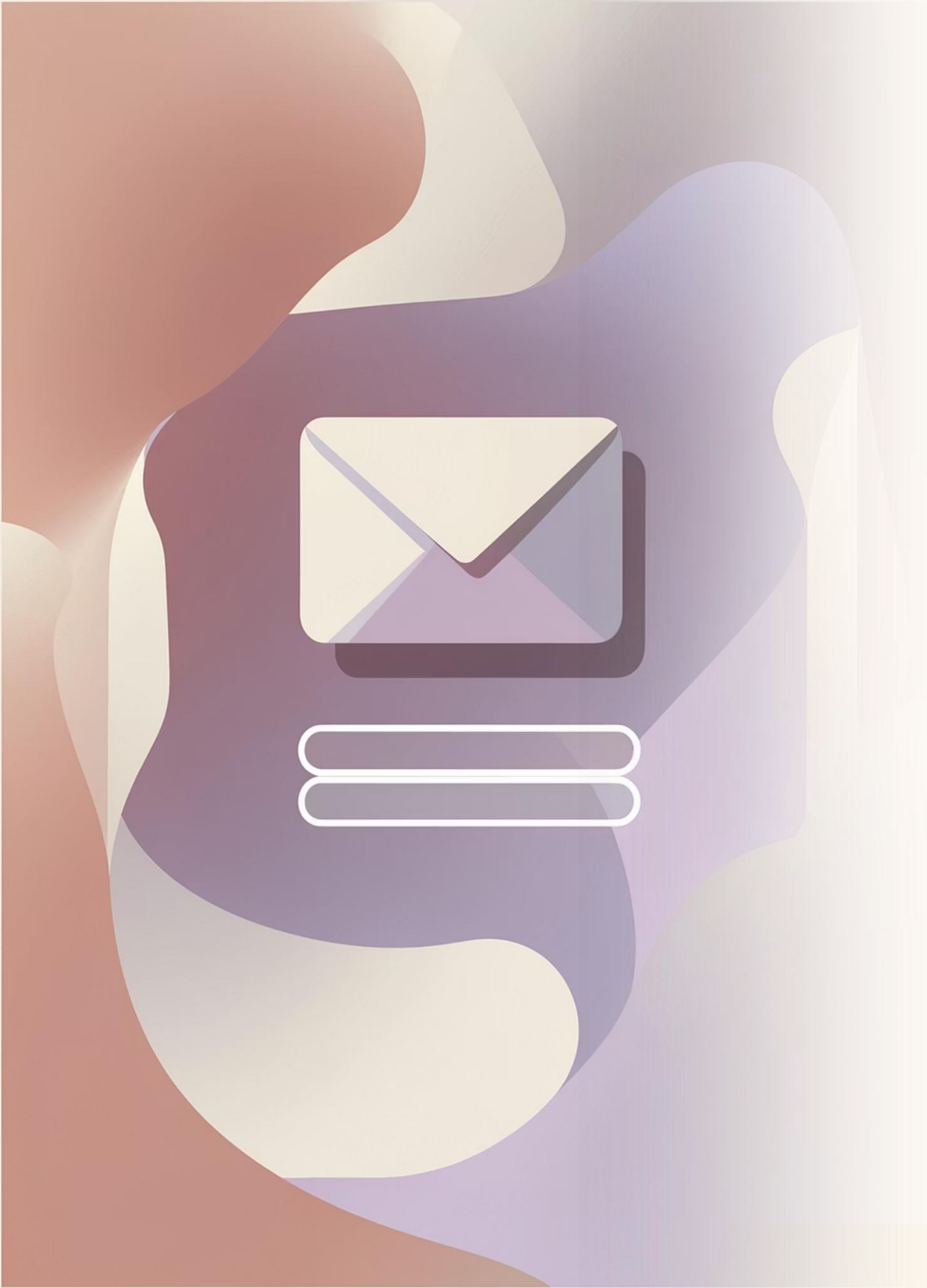


Phishing Awareness Simulation

BY : ADITYA SONUNE

Understanding Social Engineering Attacks Through Controlled Testing





Project Overview

Objective

Build a realistic phishing simulation to understand how credential harvesting attacks work and measure user vulnerability to social engineering tactics.

Method

Created a cloned Microsoft 365 login portal using Python Flask, deployed on Vercel with Firebase Firestore tracking. Sent fake password expiry emails to 10 participants.

System Architecture



Frontend Design

Cloned Microsoft 365 login page with exact colors, typography, and layout to match familiar branding.



Backend Server

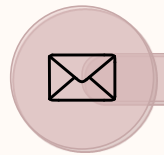
Python Flask framework serving webpage and logging interactions. Extracts email but deliberately drops password data.



Deployment & Storage

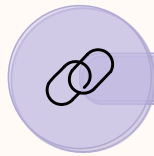
Deployed on Vercel with HTTPS. Firebase Firestore tracks interactions securely in cloud and local logs.

Simulation Methodology



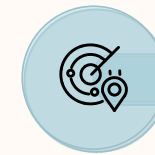
The Lure

Fake IT alert email from admin@microsoft-security-auth.com claiming password expires in 24 hours.



The Hook

Email contained "Update Password" link pointing to deployed Vercel application at microsoft-account-protection-hub.vercel.app.



Execution

Sent to 10 participants. Logged **PAGE_VISIT** and **SUBMIT_CREDENTIALS** events. Redirected to disclosure page.

Results & Analysis

10

Emails Sent

Total participants in
simulation

7

Link Clicks

70% click rate from urgency

3

Logins Attempted

30% compromise rate

43%

Conversion Rate

Of clickers attempted login

Urgency tactic proved highly effective at driving clicks. Some users noticed URL wasn't **microsoft.com** and closed it. Three trusted familiar UI and submitted emails, proving brand familiarity overrides caution.

Key Findings

Urgency Works

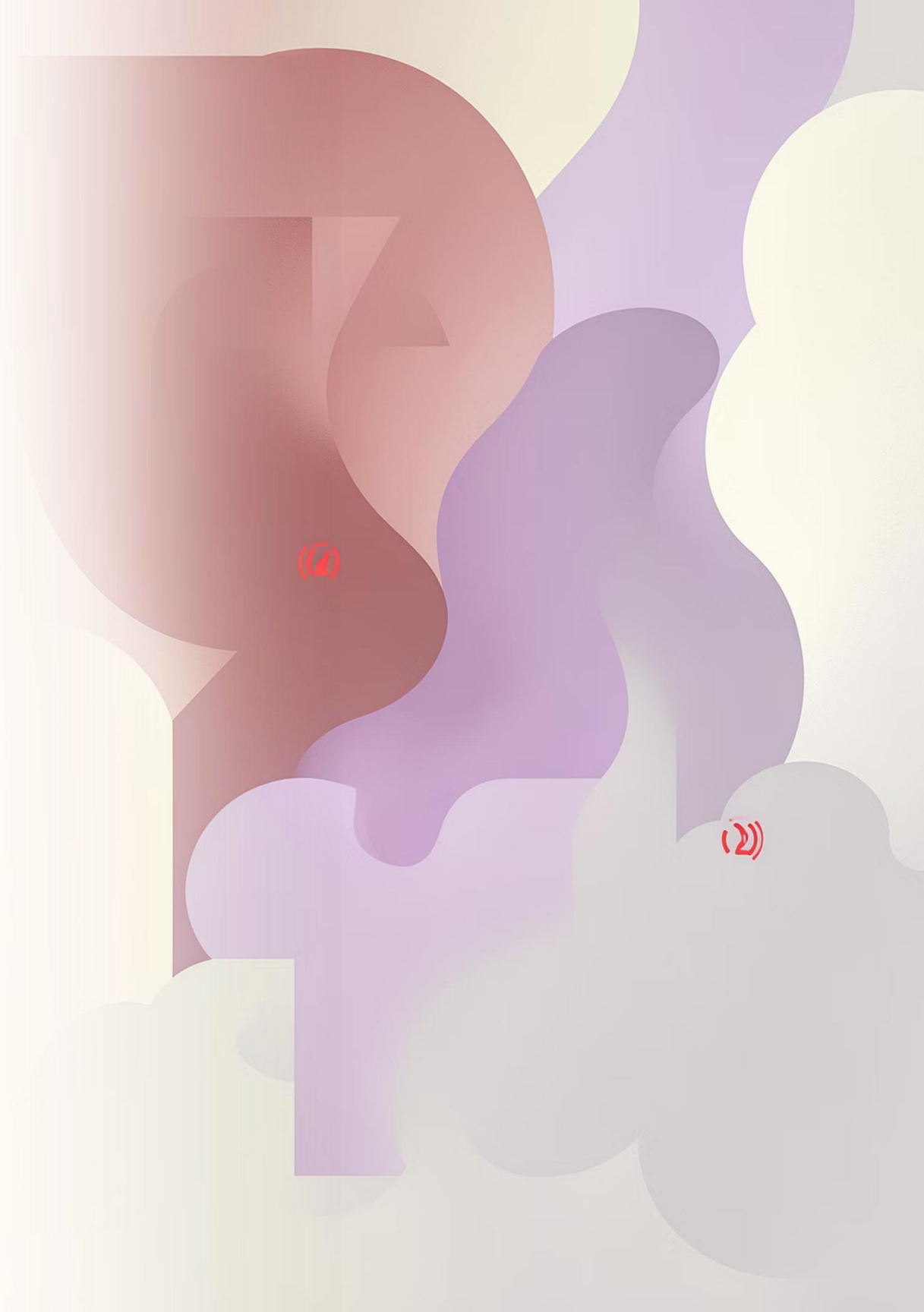
24-hour expiry warning created immediate action response in 70% of recipients.

Brand Familiarity

Microsoft 365 clone design looked authentic enough that 3 users submitted credentials despite URL mismatch.

URL Inspection

Some users checked address bar and noticed fake domain, preventing compromise.





Technical Implementation Details

Backend Logging

Local text file recorded timestamps, IP addresses, and event types. Firebase Firestore stored interaction data with email addresses and event details permanently.

Ethical Design

Password data deliberately dropped before logging. System included disclosure page confirming credentials were NOT captured or stored.

Prevention Strategies



Check the Sender

Inspect actual email address, not just display name.
Attackers easily spoof display names.



Verify the URL

Even identical websites can be fakes. Always inspect browser address bar before entering credentials.



Enable MFA

Multi-factor authentication stops attackers even if password is stolen, adding crucial security layer.



Continuous Education

Regular simulations train users to spot fake emails and suspicious links before clicking.

Conclusion

"Building this phishing simulation showed firsthand how simple it is to set up credential harvesting sites using modern web tools like Flask and Vercel."



Human Error Remains Vulnerability

Technical security measures must be paired with ongoing security awareness training.



Attack Chain Demonstrated

Simulation successfully showed complete phishing attack chain from email to credential harvesting.



Valuable Insights

Provided practical understanding of user behavior when faced with urgency and familiar branding.

Lessons Learned

Technical Simplicity

Modern web tools make credential harvesting sites easy to build.

User Education Critical

Technical defenses alone aren't enough — ongoing training is essential.

Simulation Value

Controlled tests provide practical insights into security vulnerabilities.



THANK YOU

